

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Domain 5 Exam Tips and Key Takeaways

1. Learning Objectives

By the end of this lecture, you will be able to:

- Distinguish between incident management (restore service) and problem management (eliminate root cause) and identify which is missing from a given scenario.
- Apply the RFC 3227 order of volatility to correctly sequence evidence collection actions on a compromised cloud instance.
- Explain the forensic limitations imposed by the shared responsibility model and what actions require CSP involvement.
- Describe how SIEM and threat intelligence work together and apply this to detection scenarios in exam questions.
- Use the 'prevention, detection, or response' and 'technical vs. process and people' decision framework to eliminate wrong answers in Domain 5 scenario questions.

2. Introduction

Domain 5 — Cloud Security Operations — accounts for 17% of the CCSP exam. At that weight, it is second only to Domain 1 in its contribution to your total score. But unlike Domain 1, which covers architectural concepts that candidates often find approachable, Domain 5 is where operationally experienced candidates sometimes fall into traps set by their own practical experience. The exam is testing CCSP-level thinking, which means applying frameworks and models to cloud-specific scenarios — not generalising from on-premises experience or from gut instinct developed in other security roles.

Consider a senior SOC analyst with ten years of experience who sits the CCSP exam without specific exam preparation. They know incident response thoroughly. They know forensics. But they are accustomed to operating in environments where they can seize physical media, image a hard drive, and preserve the full evidence chain. In a cloud environment, none of that applies in the same way. The exam will test whether they have shifted their thinking to cloud-native forensics — snapshots, log exports, provider-level evidence — and whether they correctly understand the shared responsibility boundary that determines what they can access versus what requires their CSP's participation. Practical experience without the conceptual framework leads to wrong answers on questions that seem intuitively obvious.

This guide consolidates the highest-yield concepts from Domain 5, maps them to the question patterns the exam uses, and provides explicit guidance on the distractors that catch even well-prepared candidates. Treat this guide as a final integration pass — a chance to make sure that everything you have learned in this domain is connected to how the exam will test it.

3. Core Concepts Explained

3.1 Incident Management vs. Problem Management

Definition: Incident management restores normal service operation as quickly as possible after a disruption, minimising business impact. Problem management identifies and eliminates the root cause of incidents to prevent recurrence. These are distinct processes with different objectives, different owners, and different timeframes.

Business relevance: Organisations that conflate these two processes end up in a reactive loop — restoring service after every incident without ever eliminating the conditions that cause the incidents in the first place. This is a critical operational failure mode that costs organisations both money and security posture.

Practitioner angle: The ITIL framework (which CCSP candidates should be familiar with at a concept level) distinguishes these explicitly. Incident management is measured by Mean Time to Restore (MTTR). Problem management is measured by the reduction in incident frequency for known problem categories. The exam will present scenarios where a team is performing good incident management but poor problem management, and ask what is missing. The answer is always a root cause analysis process, not a faster incident response tool.

Real-world example: A cloud-hosted web application experiences weekly outages due to a memory leak in a specific microservice. Each time, the operations team restores service by restarting the container. They achieve excellent MTTR. But the restart does not fix the memory leak — only a code-level fix addresses the root cause. Problem management identifies the pattern across incidents and coordinates the remediation of the underlying defect.

Risks: Without problem management, high-frequency low-severity incidents consume response resources, fatigue the team, and mask the possibility that the repeating pattern is being exploited intentionally as a denial-of-service or distraction technique.

3.2 Order of Volatility in Cloud Forensics (RFC 3227)

Definition: The order of volatility is the sequence in which digital evidence should be collected, prioritising data that is most at risk of being lost or modified first. RFC 3227 (Guide for Evidence Collection and Archiving) establishes the canonical sequence for traditional environments; cloud-specific equivalents map to cloud-native artefacts.

Business relevance: Cloud instances can be terminated — either by the attacker to cover tracks, by auto-scaling policies, or by operations teams performing normal maintenance. Once an instance is terminated in a virtualised environment, the memory contents are lost permanently. This makes the window for volatile evidence collection critically narrow in cloud environments.

Practitioner angle: In a cloud context, volatile evidence includes: memory contents (captured via VM snapshot or memory dump before termination), running process lists, active network connections and ephemeral network state, and temporary file system contents. Non-volatile evidence includes: persistent disk images, cloud provider logs (VPC flow logs, CloudTrail, Azure Monitor), and virtual machine snapshots taken at the time of compromise. The exam

consistently tests whether candidates know to capture volatile evidence BEFORE terminating a compromised instance.

Real-world example: A cloud security team identifies a compromised EC2 instance in an AWS environment. The correct sequence under RFC 3227 principles is: (1) isolate the instance from the network without terminating it, (2) capture a memory dump and running process information, (3) take a snapshot of the EBS volume, (4) export relevant CloudTrail and VPC flow log data for the instance's lifetime, and only then (5) terminate the instance for containment. Terminating first destroys all volatile evidence.

3.3 Shared Responsibility Model Applied to Forensics

Definition: The shared responsibility model defines the division of security obligations between the cloud service provider and the cloud customer. In a forensic context, this boundary determines what evidence the customer can access directly versus what requires CSP involvement or CSP-provided tooling.

Business relevance: In traditional on-premises environments, the investigating team controls the physical infrastructure and can seize any component. In cloud environments, the customer never has physical access to the underlying hardware. Evidence that exists below the virtualisation layer — hardware logs, hypervisor logs, physical media — is accessible only through the CSP. This requires a forensic engagement process with the provider, typically initiated through a law enforcement request or a formal legal process.

Practitioner angle: What cloud customers CAN access directly: VM snapshots, disk images (via provider tools), application logs, cloud provider-surfaced logs (CloudTrail, Azure Activity Log, GCP Cloud Audit Logs), network flow logs, and object storage access logs. What requires CSP involvement: anything below the virtualisation layer, physical media, hypervisor logs, and in some cases forensic engagement for multi-tenant isolation evidence.

Exam pattern: Questions that describe a forensic investigation in a cloud environment and ask what the team should do if they need physical disk evidence will have 'engage the CSP through a formal legal process' as the correct answer — not 'seize the physical hardware,' which is not possible in cloud environments.

3.4 SIEM and Threat Intelligence: Detection Architecture

Definition: A Security Information and Event Management (SIEM) system collects, normalises, and correlates log and event data from across an environment to identify patterns that may indicate security incidents. Threat intelligence is contextual information about known threats, threat actors, indicators of compromise (IoCs), and tactics, techniques, and procedures (TTPs) sourced from external feeds, vendor threat research, or information sharing communities.

Business relevance: A SIEM without threat intelligence can detect anomalies but cannot attribute them to known threat actors or known malicious infrastructure. Threat intelligence without a SIEM provides context but no mechanism for applying that context to real-time event streams. Together, they enable detection of connections to known command-and-control infrastructure,

identification of IoCs embedded in log data, and prioritisation of alerts based on threat actor relevance.

Practitioner angle: The classic exam question describes an organisation that wants to detect outbound connections to known malicious IP addresses or domains. The correct answer is SIEM integrated with threat intelligence feeds — not a firewall rule (which would need to be manually updated for every IoC), not a standalone IDS (which has no external context), and not antivirus (which operates at the endpoint file level).

Real-world example: A threat intelligence feed identifies a new command-and-control IP range used by a ransomware group. An organisation whose SIEM is integrated with this feed automatically generates high-priority alerts for any internal host that establishes a connection to those addresses — enabling detection before ransomware payload delivery rather than after encryption begins.

4. Domain 5 High-Yield Concept Comparison

Concept	Common Exam Scenario	Correct Answer Pattern	Classic Distractor
Incident vs. Problem Mgmt	Team repeatedly restores failed service; incidents recur monthly	Problem management (root cause analysis) is missing	Better incident response tooling
Order of Volatility	Compromised cloud instance found; team asked what to do before termination	Capture volatile data (memory, processes, network state) first	Terminate immediately for containment
Shared Responsibility Forensics	Team needs evidence below the virtualisation layer	Engage CSP via formal legal process	Seize physical hardware
SIEM + Threat Intelligence	Detect connections to known malicious infrastructure	SIEM integrated with threat intelligence feeds	Firewall block rules or standalone IDS
Cloud Pen Testing	Team is planning a penetration test of cloud infrastructure	Review CSP testing authorisation requirements first	Launch the test to establish baseline immediately
GDPR 72-hour Notification	Breach discovered; investigation not complete	File provisional notification; supplement later	Wait for complete investigation before filing
SOC Detection Capability	'Which control best detects' unusual behaviour by a legitimate user?	Behavioural analytics / UBA over log correlation	Signature-based IDS or antivirus
Honeypots	High-fidelity alert generation with minimal false positives	Honeypot (any interaction is inherently suspicious)	IDS with signature updates

5. Case Study and Exam Framework Application

Case Study: In 2021, a major cloud infrastructure provider experienced a DDoS attack that caused intermittent service disruptions for several customers. The affected customers' operations teams restored services by activating failover configurations — a textbook incident management response. However, several customers subsequently identified that the DDoS traffic had also functioned as a smokescreen for simultaneous data exfiltration attempts against a subset of targets. The customers who identified the exfiltration attempts did so through SIEM correlation of network flow anomalies against threat intelligence feeds that flagged the exfiltration traffic as associated with a known threat actor. Customers without integrated threat intelligence saw only the DDoS traffic and treated the event as an availability incident. This case illustrates both the SIEM-threat intelligence integration principle and the importance of problem management: the DDoS was the incident; the exfiltration attempt was the problem requiring root cause investigation.

Exam Framework Application: When approaching a Domain 5 scenario question, apply two filters sequentially. First: is the question asking about prevention (controls before an incident), detection (identifying an incident in progress), or response (actions after an incident is confirmed)? Wrong answers typically address the wrong phase. Second: is the scenario focused on the technical layer (infrastructure, logs, tools) or the process and people layer (governance, escalation, notification, root cause)? An answer that recommends a technical control in a scenario that is fundamentally about process failure, or vice versa, will be wrong — regardless of how defensible the technical control is in isolation.

6. Analogy and Memory Anchor

Think of Domain 5 exam questions like the work of an experienced aircraft accident investigator. Their first priority when they arrive at a crash site is to preserve the flight data recorder and cockpit voice recorder — the most volatile evidence — before any other recovery activity disturbs the site. They distinguish between restoring the runway (incident management) and determining why the aircraft failed (problem management). They understand that some evidence requires manufacturer involvement because it is embedded in proprietary systems they cannot access directly — equivalent to requiring CSP involvement for below-the-hypervisor forensics. And they consult a threat pattern database of known failure modes to contextualise what they find — equivalent to threat intelligence informing SIEM analysis. The investigator who seizes physical components first and asks questions later destroys evidence. So does the cloud forensic investigator who terminates an instance before capturing volatile state.

7. Exam Focus

Domain 5 at 17% of the exam means approximately 25–26 questions. High-yield areas by expected frequency:

- Incident vs. problem management distinction: appears in multiple scenario variants. The trigger pattern is a recurring incident. The missing element is always root cause analysis / problem management.

- Order of volatility and cloud forensics: the trap is 'terminate first for containment.' The correct answer is always 'capture volatile evidence before any containment action that would destroy it.'
- Shared responsibility in forensics: 'seize physical media' is always wrong in cloud scenarios. Evidence below the virtualisation layer requires CSP engagement.
- SIEM + threat intelligence for detection: 'which control detects connections to malicious infrastructure' scenarios have SIEM + TI integration as the correct answer.
- Cloud pen testing authorisation: the first step is always reviewing the CSP's authorisation requirements. Testing without provider authorisation may trigger abuse response from the provider.
- GDPR notification timelines: the 72-hour clock, phased disclosure, and the separate data-subject notification threshold are all testable. Know the distinctions cold.
- Behavioural analytics vs. signature-based detection: for detecting insider threats, account compromise, or novel attack patterns, behavioural analytics is preferred over signature-based controls.
- Honeypot characteristics: any interaction with a honeypot is inherently suspicious (no legitimate traffic), making it a high-fidelity, low-false-positive detection mechanism.
- SOC monitoring framework concepts: know that SIEM correlates events; threat intelligence provides external context; honeypots generate high-fidelity alerts; behavioural analytics catches anomalies that signatures miss.
- Two-question test for Domain 5 scenarios: (1) prevention, detection, or response? (2) technical layer or process-and-people layer? Apply both before selecting an answer.

8. Key Terms Glossary

Incident Management: The process of restoring normal service operation as quickly as possible after a disruption, focusing on recovery speed rather than root cause elimination.

Problem Management: The process of identifying and eliminating the root causes of incidents to prevent recurrence; distinct from incident management in objective, owner, and timeframe.

Root Cause Analysis (RCA): A structured analytical process for identifying the fundamental cause of an incident or recurring failure, as the basis for permanent remediation.

Order of Volatility: The RFC 3227 principle that evidence collection should prioritise the most perishable data first — memory, then running processes, then network state, then persistent storage.

RFC 3227: The IETF Request for Comments document that provides guidance on evidence collection and archiving, including the order of volatility principle.

VM Snapshot: A point-in-time copy of a virtual machine's disk state, used in cloud forensics to preserve evidence of a compromised instance before termination.

SIEM: Security Information and Event Management — a system that collects, normalises, and correlates security events across an environment to detect and investigate incidents.

Threat Intelligence: Contextual information about known threats, threat actors, indicators of compromise, and TTPs, used to enrich detection and analysis capabilities.

Indicator of Compromise (IoC): A piece of forensic data — such as a malicious IP address, domain, file hash, or behavioural pattern — that indicates potential malicious activity.

Honeypot: A security mechanism that mimics a legitimate system or resource to attract attackers; any interaction with a honeypot is inherently suspicious, providing high-fidelity threat intelligence.

Behavioural Analytics: Security analysis that identifies anomalies in user or system behaviour relative to established baselines, rather than matching against known-bad signatures.

ITIL: Information Technology Infrastructure Library — an IT service management framework whose incident, problem, change, and service level management concepts appear in Domain 5 scenarios.

9. Quick Revision Checklist

- ☐ I can clearly distinguish incident management from problem management and identify which is missing in a scenario.
- ☐ I know the order of volatility (RFC 3227) and can apply it to a compromised cloud instance scenario.
- ☐ I understand that terminating a cloud instance before capturing volatile evidence destroys forensic data.
- ☐ I can describe what cloud customers can access directly for forensics versus what requires CSP engagement.
- ☐ I know that SIEM and threat intelligence work together — SIEM correlates; TI provides external context.
- ☐ I can state what type of detection is best for known-bad infrastructure (SIEM + TI) and for anomalies (behavioural analytics).
- ☐ I understand honeypot characteristics: any interaction is suspicious; high fidelity; low false positives.
- ☐ I know that cloud pen testing requires advance authorisation from the CSP before testing begins.
- ☐ I can apply the two-question framework (phase? layer?) to eliminate wrong answers in scenario questions.

☐ I know GDPR notification timelines, phased disclosure, and the separate regulator vs. data subject thresholds.

10. Practice Questions

Q1 [SCENARIO]

SCENARIO: A cloud operations team has responded to the same service outage four times in the past two months. Each time, they restore service within 30 minutes by restarting a specific microservice container. MTTR consistently meets SLA targets. However, the outages continue to recur, always triggered by the same microservice. The security team suspects the pattern may be an intentional denial-of-service mechanism. Which of the following process improvements is MOST appropriate?

A. Implement automated container restart to further reduce MTTR.

INCORRECT. The team's MTTR is already meeting SLA targets. Reducing MTTR further does not address the underlying cause of the recurring failure. Automation without root cause elimination simply accelerates the cycle of incident and recovery.

B. Initiate a formal problem management process to identify and eliminate the root cause of the recurring microservice failure.

CORRECT. This is a textbook problem management scenario. The team has effective incident management (good MTTR) but no problem management (root cause analysis and elimination). The recurring pattern is the indicator that problem management is missing. The security concern (intentional DoS) makes root cause identification even more urgent.

C. Escalate incident management responsibility to a more senior operations team.

INCORRECT. The incident management process is performing well — the issue is that it never leads to root cause elimination. Escalating incident management ownership does not change that structural gap.

D. Increase monitoring frequency on the microservice to detect the next outage faster.

INCORRECT. Faster detection reduces time-to-awareness, not time-to-root-cause. The problem is not that outages are detected slowly — they are already contained quickly. The problem is that they keep happening.

Q2 [SCENARIO]

SCENARIO: A cloud security team identifies a compromised Linux VM running in an IaaS environment. The VM appears to be actively communicating with an external IP address. The team needs to preserve forensic evidence for a potential legal proceeding. Which of the following is the CORRECT sequence of initial actions?

A. Immediately terminate the VM to stop the exfiltration, then request the cloud provider's logs.

INCORRECT. Terminating the VM first destroys all volatile evidence — memory contents, running processes, active network connections. This evidence is required for the legal proceeding and cannot be recovered after termination.

B. Isolate the VM from the network to stop exfiltration, capture volatile evidence (memory, process list, network connections), take a disk snapshot, then terminate.

CORRECT. This is the order of volatility applied to a cloud environment. Network isolation stops the active exfiltration without destroying volatile evidence. Volatile capture comes before disk snapshot. Disk snapshot comes before termination. This sequence preserves the most complete evidence chain.

C. Take a disk snapshot first, then terminate the VM, as disk contents are the primary forensic artefact.

INCORRECT. Disk snapshots capture non-volatile state. Memory, running processes, and active network connections are more volatile and must be captured first. Taking a disk snapshot first misapplies the order of volatility.

D. Do nothing until the cloud provider's security team can lead the forensic investigation.

INCORRECT. The customer is responsible for their own evidence preservation within their layer of the shared responsibility model. Waiting for the provider cedes both time and evidence. The provider's involvement is needed only for evidence below the virtualisation layer.

Q3 [SCENARIO]

SCENARIO: A security analyst at a financial services company is reviewing alert data. Over the past 48 hours, five different internal workstations have made brief outbound connections to IP addresses that are listed in a third-party threat intelligence feed as command-and-control infrastructure for a known ransomware group. Which of the following security controls BEST explains how these connections were detected?

A. An IDS with updated signatures detecting known malware traffic patterns.

INCORRECT. A signature-based IDS would detect known traffic patterns, but command-and-control connections to a specific IP range require integration with an up-to-date threat intelligence feed. Signatures alone do not automatically incorporate real-time IoC data from external sources.

B. A SIEM integrated with threat intelligence feeds that flagged connections to known malicious IP addresses.

CORRECT. SIEM integration with threat intelligence feeds is specifically designed for this detection pattern — correlating observed network events with external threat intelligence IoCs. This is one of the highest-yield Domain 5 concepts, tested via exactly this type of scenario.

C. Antivirus software on the affected workstations detecting ransomware payload installation.

INCORRECT. Antivirus operates at the endpoint file level and detects payloads after they are delivered. It does not detect outbound command-and-control connections, and the scenario involves connections before any payload is mentioned.

D. A firewall rule blocking outbound connections to known malicious IP ranges.

INCORRECT. A firewall rule could prevent connections but would not generate the detection event described. Also, firewall rules for specific threat actor IP ranges require continuous manual updates from threat intelligence, making SIEM + TI integration a more effective and scalable approach.

Q4

A cloud security team is planning a penetration test of their organisation's cloud-hosted web application. The application runs entirely within a major public cloud provider. What is the MOST important initial step before testing begins?

A. Obtain written permission from the organisation's board of directors.

INCORRECT. Internal authorisation is necessary but not sufficient. The more critical initial step in a cloud context — the one the CCSP exam is testing — is understanding and complying with the cloud provider's testing authorisation requirements. Testing without provider authorisation can trigger abuse responses.

B. Review the cloud service provider's penetration testing authorisation policy and obtain any required approval before testing.

CORRECT. Cloud providers have explicit policies governing what may be tested, how notice must be given, and what activities require advance approval. Testing without reviewing and complying with these policies may result in account suspension or legal action. This is the CCSP-level correct answer for cloud pen testing initiation.

C. Deploy monitoring tools to establish a pre-test security baseline.

INCORRECT. A baseline is good practice, but the sequence is wrong. Without first confirming that the test is authorised by the CSP, establishing a baseline is premature — the test may not be permitted as planned.

D. Conduct a preliminary vulnerability scan to identify targets before engaging the pen testing team.

INCORRECT. Scanning is a test activity and is subject to the same CSP authorisation requirements as full penetration testing. Scanning before authorisation confirmation is a compliance violation.

Q5

Which of the following BEST describes the limitation of the shared responsibility model as it applies to cloud forensic investigations?

A. Cloud customers have no ability to collect forensic evidence in cloud environments.

INCORRECT. Cloud customers have significant forensic capability within their layer of responsibility — VM snapshots, log exports, disk images via provider tools. The limitation is specific to evidence below the virtualisation layer, not all forensic evidence.

B. Cloud customers can collect evidence within their layer of the model, but evidence at or below the virtualisation layer requires CSP involvement, typically through a formal legal process.

CORRECT. This is the precise limitation. Customers can access and preserve evidence within their layer (disk images, application logs, cloud-surfaced logs). Physical media, hypervisor logs, and below-the-virtualisation evidence require CSP participation, typically via legal process or formal forensic engagement.

C. Forensic evidence in cloud environments is exclusively the responsibility of the cloud service provider.

INCORRECT. This inverts the model. Customers are responsible for forensic evidence within their layer — application code, data, OS configuration, and cloud-surfaced logs. The CSP is responsible only for the infrastructure below the customer's control boundary.

D. Virtual machine snapshots are not considered legally admissible forensic evidence.

INCORRECT. VM snapshots are widely used in cloud forensics and are generally accepted as forensic evidence when properly documented with chain-of-custody records. The admissibility concern applies to process and documentation, not the snapshot format itself.

Q6

A CCSP candidate is reviewing Domain 5 concepts and encounters a scenario question that describes an organisation deploying a system that generates no alerts for normal user activity but immediately fires a high-confidence alert when any connection attempt is made. Which security control does this describe?

A. Signature-based intrusion detection system.

INCORRECT. Signature-based IDS generates alerts for traffic matching known attack signatures, including some false positives from benign traffic. It does not have the property that all interactions are inherently suspicious.

B. Honeypot.

CORRECT. A honeypot mimics a legitimate system but has no legitimate purpose — no authorised user should ever connect to it. Any connection attempt is therefore inherently suspicious, producing high-confidence, near-zero false-positive alerts. This characteristic is a key differentiator tested in Domain 5.

C. Security information and event management (SIEM) system.

INCORRECT. A SIEM collects and correlates events from across the environment and generates alerts based on correlation rules. It does not have the property that all interactions with it are inherently suspicious — it is a collection and analysis system, not a deceptive target.

D. Behavioural analytics platform.

INCORRECT. Behavioural analytics detects anomalies in user or system behaviour relative to baselines. It does not operate on the principle that all interactions are inherently suspicious — it requires normal behaviour as a reference point.

Q7

Which of the following BEST describes the operational frameworks most relevant to Domain 5 of the CCSP exam?

A. COBIT for IT governance and ISO 31000 for risk management.

INCORRECT. COBIT and ISO 31000 are relevant to other CCSP domains (governance and risk). Domain 5 is primarily assessed through ITIL (service management concepts) and NIST SP 800-61 (incident response). Neither COBIT nor ISO 31000 is the primary Domain 5 framework.

B. ITIL for service management concepts (incident, problem, change, service level management) and NIST SP 800-61 for incident response.

CORRECT. These are the two frameworks the CCSP exam uses as the primary context for Domain 5 operational scenarios. ITIL provides the conceptual vocabulary for incident vs. problem management, change management, and SLA concepts. NIST SP 800-61 provides the incident response lifecycle framework.

C. NIST SP 800-53 for security controls and CIS Benchmarks for configuration hardening.

INCORRECT. These are important frameworks for other CCSP domains (security controls, configuration management) but are not the primary frameworks for Domain 5 operational scenarios. NIST SP 800-53 is about control selection, not operational management processes.

D. PCI DSS for payment security and HIPAA for healthcare data protection.

INCORRECT. These are sector-specific compliance frameworks. While they may appear in regulatory context scenarios, they are not the primary operational frameworks tested in Domain 5. ITIL and NIST SP 800-61 are the correct Domain 5 frameworks.

Q8

An exam scenario describes a security operations team that is effective at detecting known attack patterns but consistently fails to detect insider threats and compromised legitimate accounts performing anomalous but not signature-matching actions. Which detection capability gap does this describe?

A. Insufficient signature-based IDS rule coverage.

INCORRECT. The scenario explicitly states the team detects known attack patterns — implying signatures are adequate for known threats. The gap is in detecting anomalies that signatures cannot match, which is a different problem than signature coverage.

B. Absence of behavioural analytics / user and entity behaviour analytics (UEBA) capability.

CORRECT. Insider threats and compromised legitimate accounts perform actions that may be individually legitimate but are anomalous in context, frequency, or combination. Signature-based systems cannot detect these because no specific signature exists. UEBA / behavioural analytics detects deviations from established baselines — precisely the capability gap described.

C. Inadequate threat intelligence feed integration.

INCORRECT. Threat intelligence is most valuable for detecting connections to known-bad external infrastructure. It does not address insider threat or anomalous behaviour by legitimate accounts, which have no external IoC signature.

D. Insufficient log retention period for the SIEM.

INCORRECT. Log retention affects the lookback period for investigation, not the real-time detection capability. The scenario describes a detection failure, not an investigation failure.

Q9

When approaching a Domain 5 CCSP scenario question, which two-question framework helps eliminate wrong answers most effectively?

A. Is this a technical or administrative control? Is the control preventive or detective?

INCORRECT. While this is a useful general security framework, it is not the Domain 5-specific framework described in the lecture. It does not address the phase (prevention/detection/response) distinction or the layer (technical vs. process-and-people) distinction that the lecture emphasises.

B. Is the question asking about prevention, detection, or response? And is the context about the technical layer or the process-and-people layer?

CORRECT. This is the two-question framework explicitly described in the lecture for Domain 5 scenarios. Most wrong answers in Domain 5 address the wrong phase (e.g., a detection control in a response scenario) or the wrong layer (e.g., a technical control in a process failure scenario).

C. Is this a cloud service provider responsibility or a customer responsibility? And does it involve IaaS, PaaS, or SaaS?

INCORRECT. The shared responsibility model is relevant to some Domain 5 questions, particularly forensics scenarios. But it is not the primary filtering framework for all Domain 5 scenario questions. The phase/layer framework is more broadly applicable.

D. Which CCSP domain does this concept belong to? And which regulatory framework applies?

INCORRECT. Domain attribution and regulatory mapping are useful study tools but are not the operational decision framework for answering Domain 5 scenario questions under exam conditions.

Q10

A CCSP exam scenario describes an organisation that continuously discovers new vulnerabilities in its cloud infrastructure but never eliminates the conditions that allow those vulnerabilities to persist — for example, permissive IAM policies, unpatched OS images, and default credentials all recur across new instances. Which process is MOST clearly absent?

A. Incident management — the organisation needs a faster response to each discovered vulnerability.

INCORRECT. Speed of individual response is not the issue. The scenario describes structural, recurring conditions that are never permanently fixed — precisely the domain of problem management. Faster incident response without root cause elimination simply recycles the same work.

B. Problem management — the organisation lacks a process for identifying and eliminating the root causes of recurring security weaknesses.

CORRECT. The recurring nature of the vulnerabilities across new instances indicates that the conditions enabling them — overly permissive IAM defaults, unpatched base images, default credential policies — have not been identified as root causes and eliminated. Problem management addresses exactly this: finding why incidents and weaknesses keep recurring and fixing the underlying conditions.

C. Change management — the organisation needs a formal approval process for infrastructure changes.

INCORRECT. Change management governs how changes are approved and implemented. While poor change management may contribute to the problem, it does not address the root cause identification and elimination that is the core gap described.

D. Service level management — the organisation needs SLAs with stricter uptime requirements.

INCORRECT. SLA management governs availability and performance commitments. It does not address recurring security vulnerability conditions. Stricter SLAs without root cause analysis would still result in the same vulnerabilities appearing in new instances.